

HFAI Security Questionnaire (CAIQ-Lite)

Version 1.0 · 2026-04-16 · hfa-i.org

This document provides pre-filled answers to the Cloud Security Alliance's Consensus Assessments Initiative Questionnaire (CAIQ-Lite) for HFAI — the runtime AI governance and EU AI Act compliance platform. It is designed to accelerate vendor security review.

Contact: security@hfa-i.org | **Trust Center:** hfa-i.org/trust

1. Application & Interface Security

ID	Question	Response
AIS-01	Are application security controls (input validation, output encoding) in place?	Yes. All inputs validated server-side. Outputs sanitized. CSP headers enforced.
AIS-02	Are security tests performed prior to release?	Yes. Vitest unit tests, TypeScript strict mode, and automated linting on every commit.

2. Audit Assurance & Compliance

ID	Question	Response
AAC-01	Are independent third-party audits conducted?	SOC 2 Type II in progress (target Q3 2026). Underlying infrastructure (AWS + Supabase) is SOC 2 Type II, ISO 27001, and HIPAA certified.
AAC-02	Are immutable audit trails maintained?	Yes. Every human review is recorded with a SHA-256 cryptographic hash chain in the human_reviews table — tamper-evident by construction.
AAC-03	Compliance frameworks supported?	EU AI Act (Articles 4–73), ISO/IEC 42001, NIST AI RMF, GDPR, CCPA.

3. Business Continuity & Operational Resilience

ID	Question	Response
BCR-01	Is there a documented disaster recovery plan?	Yes. Inherited from AWS multi-AZ deployment. RPO < 5 min (continuous WAL backup), RTO < 1 hour.
BCR-02	Are backups encrypted and tested?	Yes. Daily encrypted backups with point-in-time recovery up to 7 days (Pro+) / 30 days (Sovereign).

4. Change Control & Configuration Management

ID	Question	Response
CCC-01	Are infrastructure changes version-controlled?	Yes. All schema changes via migration files in git. All deploys traceable.
CCC-02	Are production deploys peer-reviewed?	Yes. PR-based workflow with mandatory review.

5. Data Security & Information Lifecycle

ID	Question	Response
DSI-01	Is data encrypted at rest?	Yes. AES-256 at rest (AWS RDS / Supabase managed).
DSI-02	Is data encrypted in transit?	Yes. TLS 1.2+ enforced for all client <-> server, server <-> database, and webhook deliveries.
DSI-03	Is multi-tenant data isolation enforced?	Yes. Row-Level Security (RLS) policies enforced on all customer-data tables. Cross-org access is database-level impossible.
DSI-04	Is customer data segregated logically?	Yes. Every customer table has org_id and a corresponding RLS policy gated by auth.uid() membership.
DSI-05	Is sensitive data masked in logs?	Yes. AI input/output text stored separately; PII detection runs on ingestion path.
DSI-06	Data residency options?	EU (Frankfurt) and US (Virginia) regions available. Sovereign tier supports customer-controlled S3 export.

6. Encryption & Key Management

ID	Question	Response
EKM-01	Are encryption keys managed via a KMS?	Yes. AWS KMS with automatic rotation.
EKM-02	Are API credentials hashed/encrypted at rest?	Yes. Customer API keys are hashed; provider API keys (OpenAI, etc.) are encrypted with envelope encryption.

7. Governance & Risk Management

ID	Question	Response
GRM-01	Is there an information security policy?	Yes. Reviewed annually. Available under NDA.

ID	Question	Response
GRM-02	Are risk assessments performed?	Yes. Quarterly self-assessment. Annual penetration test (Sovereign tier).

8. Human Resources Security

ID	Question	Response
HRS-01	Are background checks performed on staff with prod access?	Yes. All personnel with production database access undergo identity verification.
HRS-02	Is security training provided?	Yes. Annual security awareness training mandatory.

9. Identity & Access Management

ID	Question	Response
IAM-01	Is multi-factor authentication available?	Yes. TOTP-based MFA available on all customer accounts via /customer/security.
IAM-02	Is SSO/SAML available?	SAML 2.0 SSO available on Enterprise and Sovereign tiers.
IAM-03	Is role-based access control implemented?	Yes. Strict 3-role separation (Admin, Reviewer, Customer) with reviewer permission granularity.
IAM-04	Are passwords checked against breach databases?	Yes. HaveIBeenPwned integration enforced on signup and password change.
IAM-05	Are inactive sessions terminated?	Yes. JWT tokens expire; refresh requires active session.

10. Infrastructure & Virtualization Security

ID	Question	Response
IVS-01	Are production environments segregated from non-production?	Yes. Separate AWS accounts.
IVS-02	Are network controls (firewalls, WAF) deployed?	Yes. AWS WAF + Cloudflare DDoS protection.

11. Interoperability & Portability

ID	Question	Response
IPY-01	Can customers export their data?	Yes. Full JSON export of all governance data via Compliance Export. Sovereign tier includes nightly auto-export to customer-owned S3.
IPY-02	Are open standards used?	Yes. REST APIs, JSON, OpenAPI documentation, standard webhook signatures (HMAC-SHA256).

12. Mobile Security

ID	Question	Response
MOS-01	Is the application mobile-responsive with secure controls?	Yes. Web-only, fully responsive. No native mobile app surface area.

13. Security Incident Management

ID	Question	Response
SEF-01	Is there an incident response plan?	Yes. Documented IRP. Customer notification within 72 hours of confirmed breach (GDPR Art. 33 aligned).
SEF-02	Are incidents logged?	Yes. Tamper-evident audit_logs table + integration with PagerDuty/Datadog (Enterprise+).

14. Supply Chain Management & Transparency

ID	Question	Response
STA-01	Are sub-processors disclosed?	Yes. Published list at hfa-i.org/trust . Sub-processors: AWS, Supabase, Stripe, Resend, Cloudflare.
STA-02	Is a DPA available?	Yes. GDPR-compliant Data Processing Agreement available on request.

15. Threat & Vulnerability Management

ID	Question	Response
TVM-01	Are dependencies scanned for vulnerabilities?	Yes. npm audit + Dependabot + Snyk scanning on every build.
TVM-02	Are penetration tests performed?	Annual third-party pentest (Enterprise tier and above).

Appendix A — Inherited Compliance

HFAI is built on infrastructure with the following independently audited certifications, which apply transitively to data hosted on the platform:

- **AWS**: SOC 1/2/3, ISO 27001/27017/27018, PCI DSS, HIPAA, FedRAMP, GDPR
- **Supabase** (managed Postgres): SOC 2 Type II, HIPAA-eligible
- **Stripe** (billing): PCI DSS Level 1
- **Cloudflare** (edge/DDoS): SOC 2 Type II, ISO 27001

Appendix B — HFAI-Specific Roadmap

- SOC 2 Type II — In progress, target Q3 2026
- ISO/IEC 27001 — Statement of intent filed; certification target 2027
- CSA STAR Level 1 (self-assessment) — Submitted

This document is provided as a vendor security pre-disclosure. For deeper technical questions or to receive a custom-scope security review, contact security@hfa-i.org.